



PHISHING INCIDENT

Executive Briefing

Investigation results, business impact, and recommended actions.

Prepared by: Adebisi Damilola SOC Analyst

Classification: Cybersecurity Team

Why We're Here Today

A phishing email impersonating Microsoft's account security team was sent to a MediSure employee. Our SOC team investigated it from end to end confirming whether it was a genuine threat, how far it spread, and what it exposed.



Determine whether the email was a real threat or a false alarm



Identify which staff, systems, or accounts were affected



Understand what allowed it to reach an employee's inbox in the first place



Put in place the response needed to close the gap and prevent repeat incidents

What Happened

1

The email arrived

A message impersonating “Microsoft account team” warned of a suspicious sign-in from Russia, urging the recipient to “secure their account” via a link.

2

It was never a real Microsoft email

It failed every standard check used to verify a sender's identity. The reply address was a personal Gmail account, not Microsoft.

3

It wasn't built just for us

The same template and fake “Russia sign-in” claim has been used against other organizations since 2022 this is a reused, circulating attack.

FINDINGS

What Our Investigation Confirmed



2 of 3

staff accounts clicked the malicious link



1

account had a follow-on login attempt from a foreign IP



0

successful unauthorized logins, the attempt failed

Root Cause

The email passed through because our mail system did not enforce DMARC: a standard email authentication policy that rejects unverified senders. Without it, a spoofed “Microsoft” sender was never blocked before reaching an inbox. This is a fixable, known gap, not a sophisticated new attack method.

What Was at Stake



Regulatory Exposure

Had patient data been exposed, HIPAA fines run up to \$1.9M per violation, alongside mandatory breach notification to every affected patient.



Reputational Risk

MediSure serves over 1.5 million patients. A public breach directly erodes the trust patients place in our care and our data handling.



Operational Risk

Credential theft is typically the first step toward broader system compromise including ransomware that can take clinical systems offline.

How We Responded



Isolated the two devices that had contacted the attacker's infrastructure



Reset credentials and required re-verification for all three affected accounts



Blocked the sender domain, malicious link, and attacker IP address across our systems



Quarantined the phishing email across every mailbox it reached



Confirmed the foreign login attempt did not succeed, no patient data was accessed

Closing the Gap

▶ Enforce DMARC organization-wide

The single highest-impact fix. This would very likely have blocked this exact email from being delivered.

▶ Expand phishing simulation training

Two of three test accounts clicked the link. Regular, realistic simulations build the habit of pausing before clicking.

▶ Require MFA on all critical systems

Ensures a stolen password alone is not enough to compromise an account.

▶ Review executive and department-head accounts specifically

Confirm no higher-value accounts were targeted, and apply stronger protections where warranted.



A Fixable Gap, Closed Before It Was Exploited

No patient data was accessed. The response is complete, and the root cause, a missing email authentication policy has a clear, known fix already underway.

Questions & Discussion